

Manual 03 - NIST AI Risk Management Framework Implementation

CONTROLLED PUBLICATION QA CANDIDATE

Controlled source revision: 415cb1bb4afcda24109137eca1d6890462458cd8 | Language: en | NIST AI RMF 1.0 / NIST AI 100-1 baseline; version-aware and subject to source-watch controls.

Assurance boundary: This practical implementation manual does not certify an AI system, establish legal compliance, prove trustworthy-AI achievement, or provide an audit opinion.

Implementation paths and operating model

Manual 03 — NIST AI RMF Implementation Paths

Controlled baseline: NIST AI RMF 1.0 (NIST AI 100-1) with NIST AI 600-1 applied when generative AI is in scope.

Version warning: NIST states that AI RMF 1.0 is being updated. This implementation entry is version-bound to the currently published AI RMF 1.0 baseline and must be impact-reviewed when NIST publishes a revision.

1. Choose the implementation path by risk and complexity

Do not choose a path only by employee count. Start with the least complex path that can still control the organization's actual AI risk, lifecycle, affected parties, regulatory exposure, autonomy, scale, third-party dependence, and potential consequences.

Manual 03 memory graphic 1

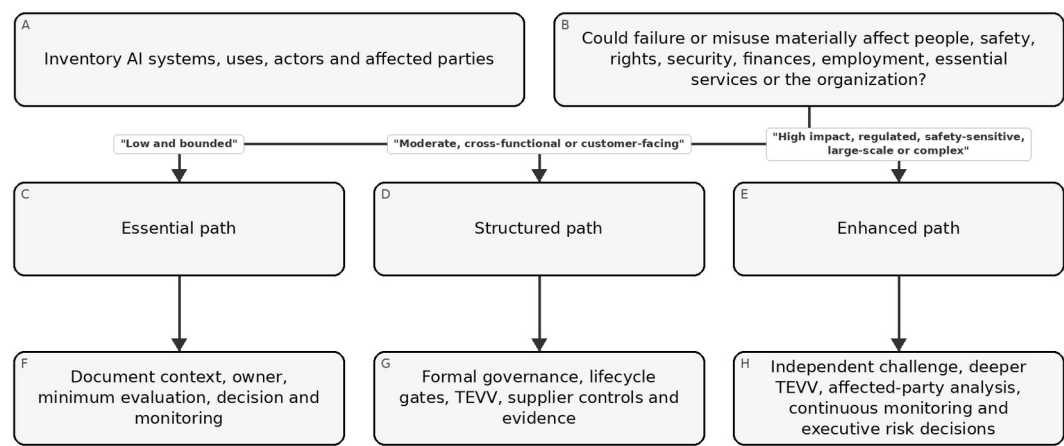


Figure 1. Implementation memory graphic

Accessible explanation: First inventory AI systems and their context. Low, bounded uses can begin with an Essential path. Moderate or cross-functional/customer-facing uses need a Structured path. High-impact, regulated, safety-sensitive, large-scale, or complex uses need an Enhanced path with stronger independence, evaluation, monitoring, and decision authority. Organizations may move a system to a stronger path whenever risk or uncertainty increases.

Path	Typical context	Minimum governance expectation
Essential	Small organization or bounded AI use with limited consequences and manageable	Named owner, inventory, documented context, basic risk/impact review,

Path	Typical context	Minimum governance expectation
	dependencies	approved use, minimum testing, user guidance, monitoring and incident path
Structured	Midsize organization, customer-facing AI, multiple business units, material data/model dependencies or moderate impact	Formal AI policy/governance, cross-functional review, lifecycle gates, documented TEVV, supplier controls, metrics, change review and periodic management reporting
Enhanced	Large/complex enterprise, regulated/safety-sensitive/high-impact use, substantial autonomy/scale or severe downside	Executive risk governance, independent challenge, deeper TEVV, affected-party engagement, red teaming where appropriate, continuous monitoring, robust fallback/stop authority and documented residual-risk acceptance

Escalate above the default path when any of the following is material: children or vulnerable groups; employment, credit, healthcare, education, safety, law enforcement, essential services or other consequential decisions; autonomous actions; sensitive or high-volume data; model/provider opacity; generative or agentic AI with tool access; security-sensitive use; broad public exposure; significant legal or contractual duties; inability to reverse harm; or weak evidence about performance.

2. Build one operating cycle around GOVERN, MAP, MEASURE and MANAGE

The Core functions are mutually reinforcing rather than a one-time sequence. Governance should influence every other function, and new evidence from measurement or operations should update context and management decisions.

Manual 03 memory graphic 2

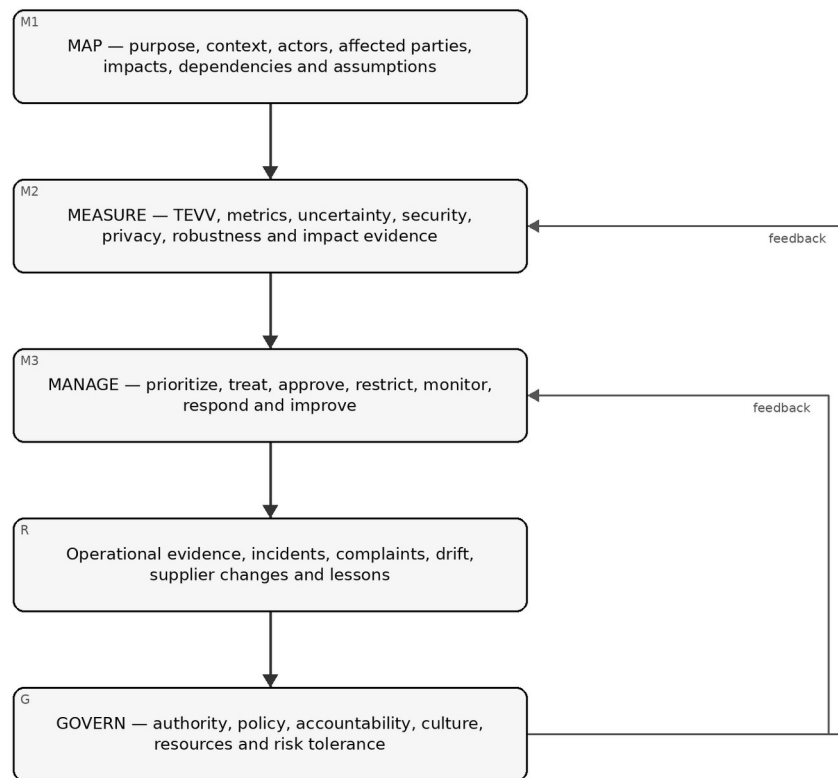


Figure 2. Implementation memory graphic

Accessible explanation: GOVERN establishes accountability and decision authority across the lifecycle. MAP describes the actual context and potential impacts. MEASURE produces evidence through testing, evaluation, verification, validation, metrics, and other analysis. MANAGE uses that evidence to prioritize and treat risk and make operational decisions. Operational evidence, incidents, complaints, drift, and supplier changes feed back into governance and renewed mapping and measurement.

Essential operating cycle

1. Name the business/system owner and responsible technical contact.
2. Record purpose, users, affected parties, data, model/provider, decision role and prohibited uses.
3. Identify plausible benefits, harms, misuse, security/privacy issues, dependency risks and uncertainty.
4. Test the system against a small but relevant set of acceptance criteria before approved use.
5. Document the decision: approve, approve with conditions, pilot, restrict or do not use.
6. Give users clear instructions, verification expectations, escalation and stop conditions.
7. Monitor key failures, complaints, incidents, provider/model changes and material drift.
8. Reassess after material change or evidence that assumptions were wrong.

Structured operating cycle

Add to the Essential path:

- cross-functional governance and risk ownership;
- documented risk criteria and decision authorities;
- lifecycle gates for intake, design/acquisition, evaluation, deployment, operation, change and retirement;
- documented TEVV plan with representative data and explicit thresholds;
- model/data/provider version control and lineage;
- privacy, cybersecurity, accessibility, human-oversight and affected-party checks where relevant;

- supplier due diligence and contract/evidence requirements;
- formal incident/complaint and corrective-action processes;
- management metrics and periodic review; and
- controlled evidence retention.

Enhanced operating cycle

Add to the Structured path:

- executive or board-level oversight for material AI risk;
- independent validation/challenge proportional to consequence;
- scenario, stress, adversarial, subgroup, misuse and failure-mode testing as relevant;
- stronger human-factors and affected-party evaluation;
- explicit fallback, rollback, kill/stop, business-continuity and manual-alternative controls;
- continuous or near-continuous monitoring for key operational risks;
- formal residual-risk acceptance with expiration/review conditions;
- enhanced vendor/subprocessor/model-change surveillance;
- exercises for major AI incidents and communications; and
- portfolio-level concentration, correlated-failure and systemic-risk analysis.

3. Convert the Core into evidence, not paperwork

Every material AI risk decision should leave a traceable chain from context to evidence to action.

Manual 03 memory graphic 3

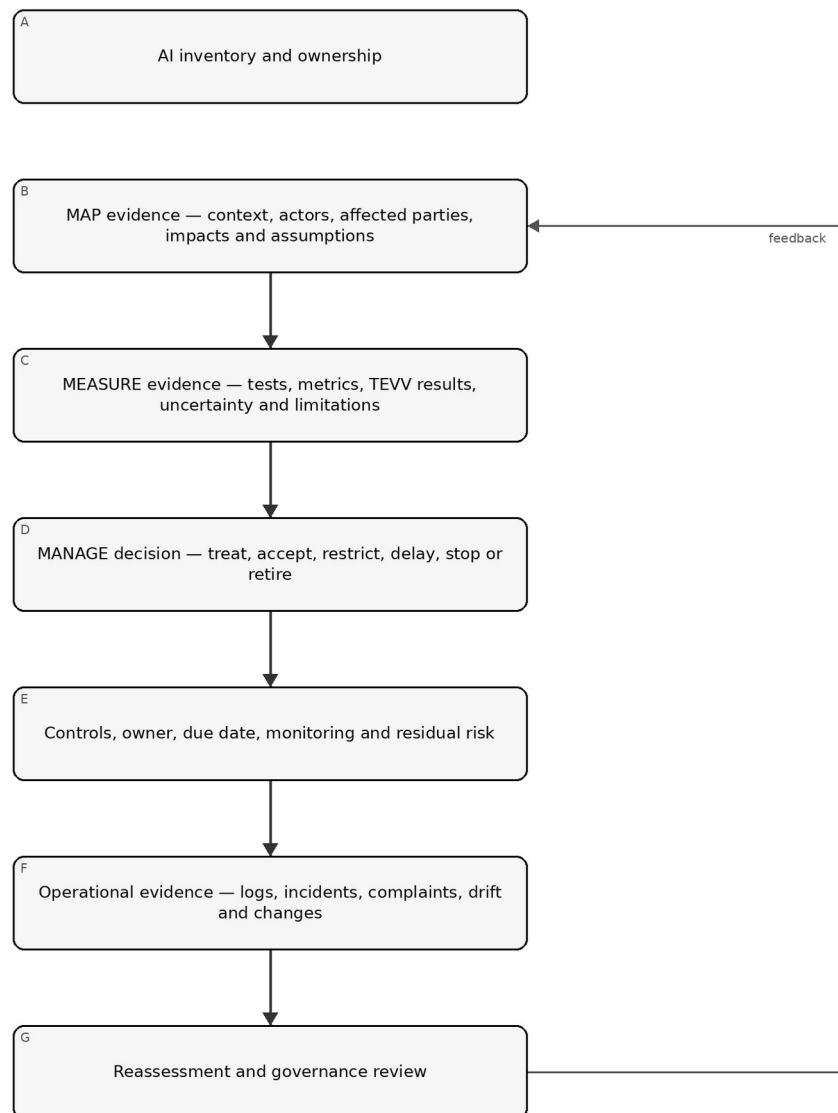


Figure 3. Implementation memory graphic

Accessible explanation: Evidence begins with an owned AI inventory, then documents context and impacts, testing and uncertainty, and the resulting management decision. Controls and residual risk are tracked into operations. Logs, incidents, complaints, drift, and changes trigger reassessment and governance review. A policy by itself is not evidence that the risk was controlled.

Minimum evidence record for a material AI system:

Evidence area	Minimum record
Identity	System/use name, owner, lifecycle stage, version, provider/model, business process and status
Context	Purpose, users, affected parties, geography, scale, decision role, dependencies and assumptions
Risk/impact	Scenarios, benefits, harms, misuse, severity, likelihood where meaningful, uncertainty and affected groups

Evidence area	Minimum record
Measurement	Evaluation method, population/data, version, thresholds, results, limitations, reviewer and date
Treatment	Controls, conditions, restrictions, human oversight, supplier actions and remediation
Decision	Authorized approver, approve/restrict/pilot/stop decision, residual risk, conditions and expiration/review trigger
Operations	Monitoring measures, complaints, incidents, drift, provider/model changes and evidence of control operation
Improvement	Corrective action, retest, lessons learned and updates to governance, context, measures or treatment

4. Apply NIST AI 600-1 when generative AI is in scope

Generative AI should not be treated as a completely separate governance system. Apply the general AI RMF operating model and then add GenAI-specific analysis and controls proportional to the use.

At minimum, evaluate as relevant:

- confabulation or unsupported output;
- harmful, illegal, unsafe or policy-violating content;
- information integrity and provenance concerns;
- privacy and sensitive-data exposure;
- intellectual-property and content-origin issues;
- prompt injection, tool abuse, data poisoning and other security threats;
- model extraction, abuse, excessive agency and unsafe automation;
- third-party foundation-model and service-provider opacity/change risk;
- human over-reliance, automation bias and inadequate review;
- misuse at scale and abuse enablement;
- evaluation limitations, benchmark contamination and poor transfer from test to production; and
- monitoring of prompts, outputs and traces with appropriate privacy and access controls.

For agentic or tool-using GenAI, add explicit authorization boundaries, least privilege, transaction limits, confirmation gates, environment isolation, tool allowlists, high-risk action blocks, logging, rollback and emergency stop controls.

5. Integrate with existing governance instead of duplicating it

Manual 03 should reuse evidence and decision systems where they are fit for purpose.

Existing capability	AI RMF integration
Enterprise risk management	AI risk criteria, aggregation, residual-risk acceptance and escalation
Security program / NIST CSF	Identity, access, logging, vulnerability, incident, resilience and supply-chain controls
Privacy program	Data purpose, minimization, rights, privacy risk, notice, retention and complaints
Product / SDLC	Requirements, lifecycle gates, testing, release, change and retirement
Data governance	Ownership, quality, provenance, access, retention and lineage
Vendor risk	Model/service due diligence, contracts, changes, incidents, evidence and exit
Quality / safety	Verification, validation, failure analysis, corrective action and continuous improvement
Internal audit / assurance	Independent testing of governance, evidence, control design and operation
ISO/IEC 42001	Management-system structure, documented control operation, audit/review and improvement

Existing capability	AI RMF integration
EU AI Act / sector law	Binding applicability and legal duties kept separate from voluntary NIST guidance

Do not say that implementing AI RMF automatically establishes ISO/IEC 42001 conformity or legal compliance. Crosswalks are evidence-reuse tools, not equivalence claims.

6. Define decision gates and stop conditions

Every organization should define who may make material AI decisions and when use must pause.

Typical decision outcomes:

- Approve: evidence meets current criteria and residual risk is within authority.
- Approve with conditions: limited use is permitted with explicit restrictions, monitoring and expiry/review.
- Pilot: uncertainty is too high for broad use; a bounded experiment is approved to generate evidence.
- Remediate before use: material control or evidence gaps must be closed first.
- Restrict: scope, population, autonomy, data or functionality is reduced.
- Stop/rollback: actual or plausible harm exceeds tolerance, critical controls fail or safe operation cannot be demonstrated.
- Retire: system is removed and dependencies, data, identities, contracts and records are handled through controlled exit.

Examples of automatic review/stop triggers should include severe incidents; material model/provider changes; unauthorized data exposure; security compromise; material performance or subgroup degradation; repeated harmful outputs; significant complaints; new affected populations or geographies; expansion into consequential decisions; loss of required human oversight; expired supplier evidence; or a new binding requirement affecting the use.

7. Measure whether AI risk management is improving

Metrics should answer management questions rather than reward paperwork volume.

Useful examples include:

- percentage of active AI uses reconciled to an accountable owner and current risk tier;
- time from intake/material change to approved risk decision;
- percentage of material systems with current evaluation evidence linked to deployed version;
- unresolved high-severity evaluation failures and their age;
- incidents, complaints, overrides, appeals and repeat failure patterns;
- drift/performance/security/privacy measures tied to action thresholds;
- percentage of critical AI suppliers with current evidence and reviewed material changes;
- overdue residual-risk approvals or exceptions;
- corrective actions retested for effectiveness within risk-based targets; and
- systems stopped, restricted or redesigned because evidence did not support continued use.

A metric is useful only when management knows what decision or action it should trigger.

8. Keep the baseline current without silently changing the manual

Because NIST has announced an AI RMF revision, Manual 03 must distinguish source monitoring from source adoption.

When NIST publishes a new AI RMF version:

9. freeze the current Manual 03 release candidate;
10. verify the exact final NIST publication and effective publication state;
11. compare the new framework against the controlled AI RMF 1.0 baseline;
12. classify changes as editorial, terminology, structural, outcome/action, implementation, crosswalk or assurance impacts;
13. identify affected chapters, templates, graphics, translations and QA controls;
14. update the English controlled source first;
15. perform human semantic review for localized changes;
16. regenerate release artifacts; and
17. publish a clear change history rather than overwriting prior guidance without explanation.

Assurance boundary: This practical implementation manual does not certify an AI system, establish legal compliance, prove trustworthy-AI achievement, or provide an audit opinion.

Controlled 32-chapter manual

1. NIST AI RMF purpose, voluntary boundary and implementation model

NIST AI RMF 1.0 is a voluntary, non-sector-specific framework for managing AI risks and supporting trustworthy and responsible AI practices.

1.1 What implementation means

Implementation means embedding risk decisions into normal organizational work. A useful AI RMF implementation therefore connects:

- strategy and risk tolerance;
- AI inventory and ownership;
- product, acquisition and lifecycle gates;
- affected-party and stakeholder analysis;
- technical and non-technical evaluation;
- data, model, software, infrastructure and supplier governance;
- cybersecurity, privacy, safety, quality and resilience;
- user instructions and human oversight;
- monitoring, complaints and incident response;
- residual-risk acceptance and escalation; and
- corrective action, learning and retirement.

1.2 What implementation does not mean

- Completing every Playbook suggestion regardless of context.
- Treating every AI system as equally risky.
- Assuming a high benchmark score proves acceptable real-world performance.
- Treating a vendor attestation as sufficient evidence for the customer's context.
- Treating AI RMF use as legal compliance, ISO/IEC 42001 certification or an audit opinion.
- Claiming that a system is “trustworthy” because a governance document exists.

1.3 A practical unit of accountability

Use the AI system/use record as the minimum unit that connects governance to operations. One record may cover a tightly controlled service or use case, but do not aggregate unrelated uses if their affected parties, decision consequences, models, data, configurations, suppliers or risk owners differ materially.

Field	Minimum content
Identity	System/use name, unique ID, owner, business process and lifecycle status
Purpose	Intended task, decision/content role, users and expected benefit
Scope	Geography, population, scale, autonomy and prohibited uses
Technology	Model/service, version, software, tools, infrastructure and integrations
Data	Inputs, outputs, sensitive data, sources, retention and key lineage
Parties	AI actors, users, affected people/groups, suppliers and reviewers
Risk	Tier, material scenarios, uncertainty, treatment and residual-risk authority
Evidence	Evaluation, approvals, monitoring, incidents, complaints and changes

2. AI risk-management architecture and the four-function operating cycle

The Core functions should reinforce each other continuously; they are not four boxes completed once.

Manual 03 memory graphic 4

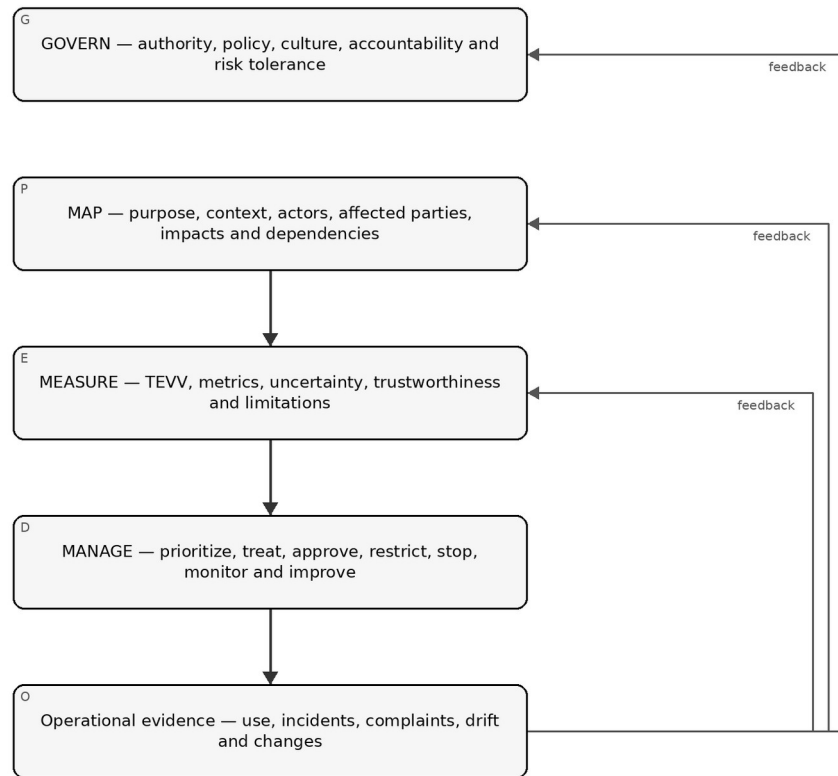


Figure 4. Chapter memory graphic

Accessible explanation: Governance establishes who can decide and how risk is handled. Mapping describes the real context and people or systems affected. Measurement creates evidence through testing and other evaluation. Management uses the evidence to treat and accept or reject risk. Operational results, incidents, complaints and changes then feed back into all four functions.

2.1 Governance is cross-cutting

Do not isolate GOVERN as an annual committee activity. Governance should determine:

- who owns each AI use;
- when legal, privacy, security, safety, accessibility or domain specialists must participate;
- what level of risk-management effort is required;
- who may approve residual risk;
- what evidence is required before deployment;
- what events require reassessment; and
- when a system must be restricted, rolled back or retired.

2.2 Profiles and tailoring

A practical implementation may create a profile for a use case, business unit or sector. Tailoring should identify:

- which AI RMF outcomes matter most in the context;
- current state and desired target state;
- risk tolerance and legal/contractual constraints;
- evidence and metrics;
- resource and independence expectations; and
- planned actions with owners and dates.

Tailoring must not be used to hide known high-consequence risks or remove a binding obligation.

3. AI inventory, actors, ownership and lifecycle boundaries

An organization cannot govern AI it cannot identify, classify and assign to accountable people.

Manual 03 memory graphic 5

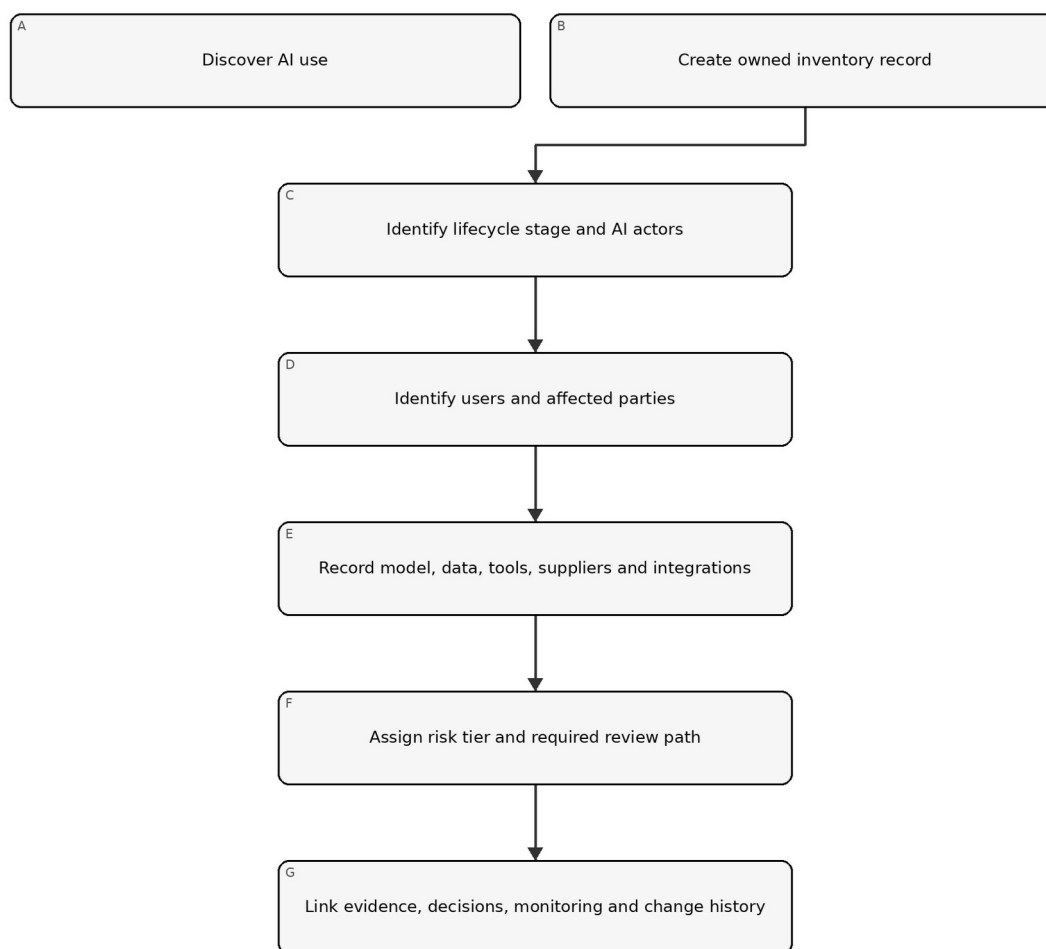


Figure 5. Chapter memory graphic

Accessible explanation: Discovery creates an inventory record. The organization then identifies who develops, supplies, operates, uses, oversees and is affected by the AI; records technical and supplier dependencies; assigns a proportional review path; and links evidence and decisions through the lifecycle.

3.1 Discovery sources

Reconcile multiple sources because self-report alone misses shadow AI:

- procurement and expense records;
- cloud and SaaS inventories;
- model/API usage and billing;
- software repositories and package dependencies;
- identity and access logs;
- endpoint/browser extension inventories;
- data catalogs and integration platforms;
- product architecture and service catalogs;
- vendor-risk records;
- interviews and employee attestations; and
- security monitoring where appropriate and lawful.

3.2 AI actors

Document roles by actual activity, not job title. Common activities include:

- executive and risk governance;
- system commissioning and product ownership;
- data acquisition, preparation and stewardship;
- model development, adaptation or configuration;
- software and infrastructure engineering;
- testing, evaluation, verification and validation;
- deployment and operations;
- human oversight and decision review;
- user support, complaint and redress;
- security, privacy, legal, compliance and safety review;
- supplier and contract management; and
- independent assurance/audit.

One person may perform several roles in a small organization, but conflicts of interest should be identified and compensating review added for material risks.

3.3 Affected parties

Affected people may never use the system. Consider people whose employment, access, eligibility, safety, reputation, finances, privacy, speech, learning, health, mobility or other interests can be influenced by the AI-enabled process.

Record:

- direct users;
- decision subjects;
- people represented in data;
- bystanders and indirectly affected groups;
- customers or workers downstream;
- communities or populations affected at scale; and
- organizations or public systems that depend on outputs.

4. Proportional risk and complexity routing

Resource intensity should follow plausible consequences, uncertainty and complexity rather than organization size alone.

Manual 03 memory graphic 6

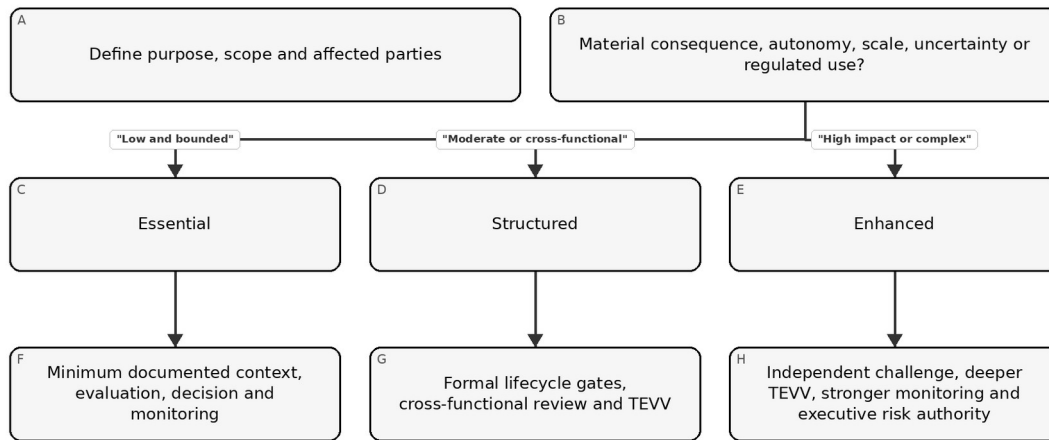


Figure 6. Chapter memory graphic

Accessible explanation: The organization starts with context and affected parties, then considers potential consequence, autonomy, scale, uncertainty and regulatory exposure. Low bounded uses may use an Essential path. Moderate uses require a Structured path. High-impact or complex uses require an Enhanced path with stronger independence and oversight.

4.1 Risk factors

Consider at least:

- severity and reversibility of plausible harm;
- number and vulnerability of people affected;
- whether the use influences consequential decisions;
- degree of automation or action authority;
- public exposure and abuse potential;
- data sensitivity and volume;
- model opacity and supplier control;
- novelty and uncertainty;
- security and safety consequences;
- geographic/legal complexity;
- ability to monitor and correct outcomes; and
- concentration or common-mode dependency risk.

4.2 Tiering record

Field	Example evidence
Inherent consequence	Narrative plus dimensions such as safety, rights, finance, security or operations
Likelihood/uncertainty	Data, expert judgment, analogous incidents, assumptions and confidence
Exposure	Scale, frequency, duration, population and geography
Autonomy	Advisory, human-approved, automatically executed or agentic/tool-using
Control strength	Existing controls and known limitations
Tier/path	Essential, Structured or Enhanced with rationale

Field	Example evidence
Authority	Person/committee authorized to approve the tier and residual risk
Review trigger	Change, incident, complaint, drift, law/provider update or scheduled review

5. GOVERN function architecture

GOVERN makes AI risk management durable by establishing policy, accountability, culture, engagement, supplier controls and review mechanisms.

The current AI RMF 1.0 GOVERN function groups outcomes into six broad themes. For implementation, treat them as:

18. organizational policy/process and risk-tolerance infrastructure;
19. accountability, training and decision authority;
20. interdisciplinary capability and human-AI oversight roles;
21. risk-aware culture, impact documentation, testing and information sharing;
22. external and internal engagement with meaningful feedback; and
23. third-party and supply-chain governance, including contingency planning.

Revision caution: Some current AI RMF 1.0 terminology is specifically identified by NIST as subject to revision.

Preserve identifier-level traceability to the controlled 1.0 baseline, but do not present today's category wording as immutable future text.

5.1 Governance evidence hierarchy

Stronger evidence moves from intent to operation:

- Intent: policy, charter, principles and risk tolerance.
- Design: defined process, roles, decision rights, templates and controls.
- Operation: completed reviews, approvals, tests, supplier actions and incident records.
- Effectiveness: evidence that controls change decisions, reduce risk or detect failures.
- Improvement: corrected causes, updated policies/processes and verified follow-through.

6. GOVERN: policy, legal obligations, risk tolerance and inventory

Policies should connect AI risk priorities to repeatable decisions rather than restating broad principles.

6.1 AI policy

A practical policy should define:

- purpose and scope;
- approved/prohibited use boundaries;
- accountability and escalation;
- risk-tiering method;
- legal/regulatory/contractual review triggers;
- data and security requirements;
- minimum evaluation expectations;
- human-oversight expectations;
- supplier controls;
- monitoring and incident duties;
- recordkeeping; and
- exceptions and enforcement.

6.2 Obligation register

AI RMF is voluntary, but AI systems may be subject to binding obligations. Maintain a separate obligation register with:

Field	Minimum content
Source	Law, regulation, contract, policy, standard or customer requirement
Jurisdiction	Country/state/sector/business relationship
Applicability	System/use/data/party/process affected
Requirement	Practical obligation stated in organizational language
Owner	Accountable function/person
Evidence	Control, record, test or approval
Change watch	Source monitor and review cadence

Do not label a voluntary NIST suggestion as law. Do not label legal compliance as achieved merely because it maps to an AI RMF outcome.

6.3 Risk tolerance and effort

Define which decisions can be made at each level. For example:

- low-risk owner approval within documented criteria;
- moderate-risk cross-functional review;
- high-risk executive/committee approval;
- mandatory escalation for prohibited or legally restricted use;
- independent challenge for high-consequence systems; and
- stop authority when critical controls fail.

The risk-management effort itself should be resourced based on risk priority.

6.4 Inventory as a governance control

The inventory should be reconciled periodically and after acquisition, deployment or material change. A stale inventory is a governance failure because downstream risk processes depend on complete population data.

7. GOVERN: accountability, competence, human oversight and effective challenge

Responsibility must be explicit enough that a material AI decision can be traced to people with authority and competence.

7.1 Responsibility model

At minimum identify:

- executive sponsor;
- business/system owner;
- technical/model owner;
- data owner/steward;
- risk/compliance/legal/privacy/security/safety reviewers as applicable;
- human-oversight role;
- supplier owner;
- incident owner;
- residual-risk approver; and
- independent assurance role where needed.

7.2 Competence

Competence is role-specific. Evidence may include education, experience, supervised practice, training, assessment and reviewed work products. High-risk evaluation requires competence in both the technology and the domain where consequences occur.

Training should cover actual decisions people make, such as:

- recognizing unapproved AI use;
- handling restricted data;
- interpreting model confidence and limitations;
- verifying outputs;
- recognizing automation bias;
- escalating safety/security/privacy concerns;
- responding to incidents; and
- using stop or fallback procedures.

7.3 Human oversight

“Human in the loop” is not sufficient by itself. Document:

- what the human sees;
- what they are expected to verify;
- time and information available;
- authority to disagree or stop;
- incentives and workload;
- competence;
- override logging; and
- evidence that intervention is effective.

A reviewer who automatically accepts AI output is not a meaningful control.

7.4 Effective challenge

For material risks, use a reviewer or group that can question assumptions and has enough authority, independence, expertise and access to evidence to affect the decision. Independence can be scaled for small organizations through peer review, external expertise or separation of approval from creation.

8. GOVERN: culture, engagement, suppliers and third-party resilience

AI risk management depends on the organization’s willingness to surface failures, hear affected perspectives and control dependencies it does not own.

8.1 Risk-aware culture

Useful practices include:

- leadership that rewards escalation of material concerns;
- protected reporting channels;
- pre-mortems and failure-mode review;
- documented dissent on high-risk decisions;
- red-team or adversarial challenge where appropriate;
- learning from incidents and near misses; and
- avoiding delivery incentives that punish safe delay or stop decisions.

8.2 Engagement and feedback

Engagement should be proportionate and meaningful, not performative. Define:

- why feedback is sought;
- which affected or expert perspectives are needed;
- how participants are selected and protected;
- accessibility and language needs;
- how feedback is recorded and adjudicated;
- what changed because of the feedback; and
- how unresolved concerns are escalated.

Feedback may come from users, affected people, workers, domain experts, customer support, complaints, appeal processes, incident databases, regulators, researchers or civil-society organizations depending on context.

8.3 Supplier and third-party governance

AI supply chains may include foundation models, APIs, datasets, open-source components, evaluation tools, cloud infrastructure, human labeling services, safety filters and orchestration platforms.

Minimum supplier evidence should address:

- exact product/model/service and version;
- intended use and contractual restrictions;
- data handling, retention and training use;
- security and privacy evidence;
- performance/evaluation evidence and limitations;
- change-notification practices;
- subprocessors/dependencies;
- incident/vulnerability notification;
- continuity, portability and exit; and
- responsibility allocation between provider and customer.

8.4 Third-party failure planning

For material dependencies, plan for:

- model/service outage;
- material quality degradation;
- silent model update;
- supplier security incident;
- loss of API/functionality;
- changed terms or data practices;
- supplier exit or service discontinuation; and
- inability to obtain evidence needed for continued risk acceptance.

Fallback may include alternate providers, safe degraded mode, manual process, traffic limiting, cached approved results, feature disablement or full stop depending on the use.

Part 1 checkpoint: Chapters 1–8 establish version awareness, inventory, proportional routing and the governance foundation. Part 2 continues with MAP and affected-context analysis.

9. MAP function architecture and context record

MAP establishes enough socio-technical context to identify relevant risks, benefits, affected parties and measurement needs.

Mapping is not a one-time questionnaire. It is a controlled description of the system as it is intended, configured, supplied and actually used. The record should be specific enough that reviewers can distinguish one deployment, population, model version or decision role from another.

Manual 03 memory graphic 7

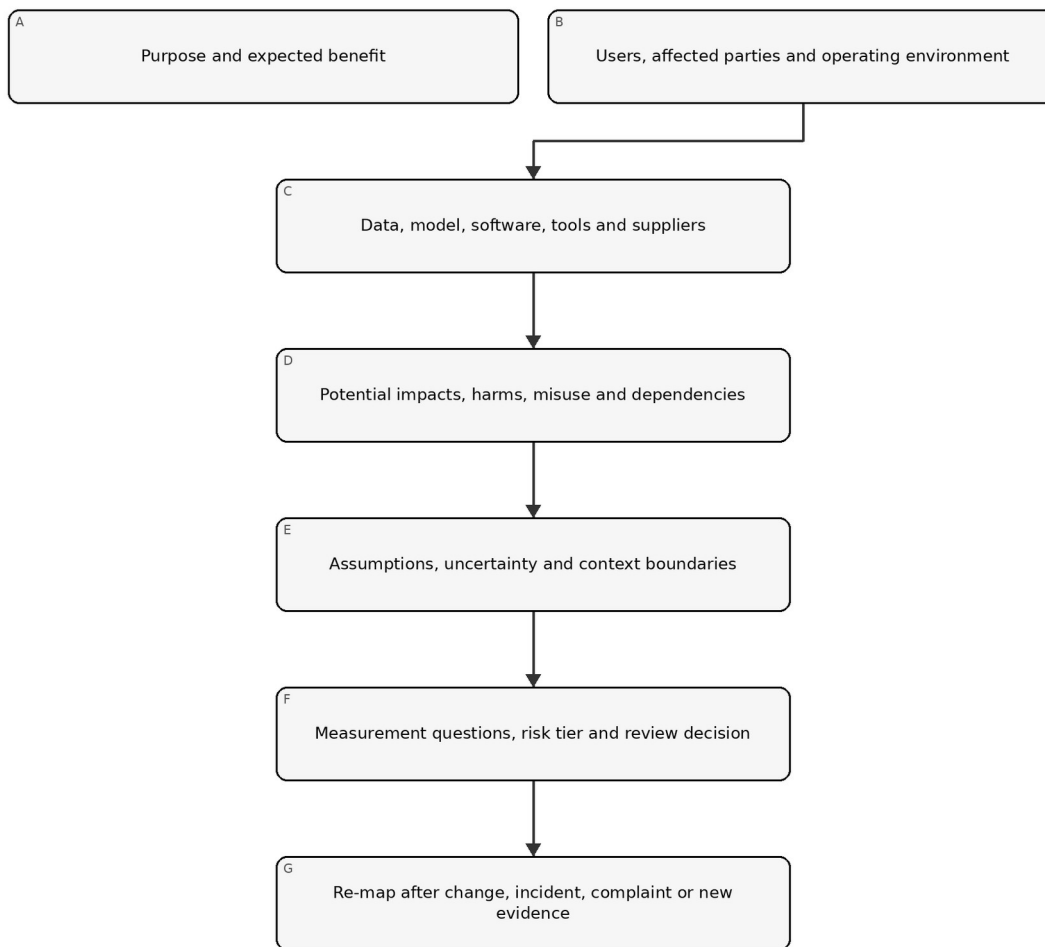


Figure 7. Chapter memory graphic

Accessible explanation: Mapping starts with purpose and expected benefit, then documents users and affected parties, technical and supplier dependencies, plausible impacts and misuse, and key assumptions. These facts determine measurement questions and risk tier. Changes, incidents, complaints and new evidence send the system back through mapping.

9.1 The context record

Maintain one controlled context record for each materially distinct AI system or use. It should link to the inventory record and include:

- business purpose and expected benefit;
- system boundary and lifecycle stage;
- AI actors, accountable owner and decision authority;
- direct users, decision subjects and indirectly affected parties;
- operating environment, geography, frequency, scale and duration;
- decision or content role and degree of autonomy;
- data, model, software, tool and infrastructure dependencies;
- third parties and contractual boundaries;
- plausible positive and negative impacts;
- reasonable misuse and failure scenarios;

- assumptions, uncertainties and evidence gaps;
- applicable requirements and stakeholder expectations;
- initial risk tier and rationale; and
- measurement questions, thresholds and review triggers.

9.2 Context quality criteria

A context record is ready for review when it is:

- specific: names the actual use, population, version and environment;
- traceable: links claims to evidence, owners and dates;
- bounded: states what is excluded and why;
- plural: considers technical, human, organizational and societal perspectives as relevant;
- challengeable: records assumptions and dissent rather than presenting certainty that does not exist;
- current: reflects the deployed or proposed configuration; and
- actionable: produces measurable questions and management choices.

Generic product descriptions, vendor marketing, policy slogans and benchmark summaries do not meet this standard by themselves.

10. Intended purpose, scope, actors and lifecycle context

Risk cannot be evaluated without defining what the AI is expected to do, where it is used and how people interact with it.

10.1 Intended purpose statement

Write the purpose in operational language:

The system assists [named users] with [specific task or decision] for [defined population/environment] by producing [output/action]. It is expected to provide [measurable benefit]. It must not be used for [prohibited or unvalidated uses].

Avoid purposes such as “improve efficiency” unless the record defines the process, user, output, consequence and metric.

10.2 Scope and boundaries

Record:

- organizational units and processes;
- jurisdictions and languages;
- user and affected populations;
- channels, devices and environments;
- operating hours and expected transaction volume;
- integrations and downstream decisions;
- advisory versus automatic action;
- human review points;
- data and model versions;
- pilot, production or retirement status; and
- excluded uses and environments.

If a single model supports different decisions, populations or autonomy levels, create linked use records rather than hiding risk variation inside one broad inventory entry.

10.3 Lifecycle context

Identify the current and planned lifecycle stages:

24. concept and intake;
25. design or acquisition;
26. data preparation and model development/configuration;
27. integration and pre-deployment evaluation;
28. pilot or limited release;
29. production use;

30. monitoring and change;
31. suspension, rollback or remediation; and
32. retirement and controlled disposal.

Different evidence is available at different stages. Early mapping relies more heavily on assumptions, analogous evidence and planned safeguards. Production mapping must incorporate observed performance, incidents, complaints, overrides, drift and supplier changes.

10.4 Actor-task mapping

Map people and organizations to actual tasks, authority and evidence. Include external providers when they develop, configure, evaluate, host or monitor part of the system.

Actor/task	Accountable activity	Required evidence
Business owner	Defines purpose, benefit, process and acceptable residual risk	Business case, purpose statement, approvals
Product/system owner	Maintains lifecycle record and coordinates gates	Inventory, context, decision log, change history
Data/model/engineering roles	Build, configure and operate technical components	Lineage, version records, design and test evidence
Domain specialist	Tests whether the system works safely in the real domain	Scenario review, acceptance criteria, limitations
Oversight user	Verifies or challenges outputs in operation	Instructions, competence, override and escalation evidence
Risk/legal/privacy/security/safety reviewers	Apply specialist requirements and risk challenge	Findings, decisions, conditions and remediation
Supplier owner	Controls provider evidence, contracts and changes	Due diligence, clauses, notices and exit plan
Assurance reviewer	Independently tests design or operation where needed	Scope, workpapers, findings and conclusion

11. Affected parties, benefits, impacts and harms

The relevant unit of analysis is not only the user or customer; it includes people, groups, organizations and systems influenced by the AI-enabled process.

11.1 Affected-party map

Manual 03 memory graphic 8

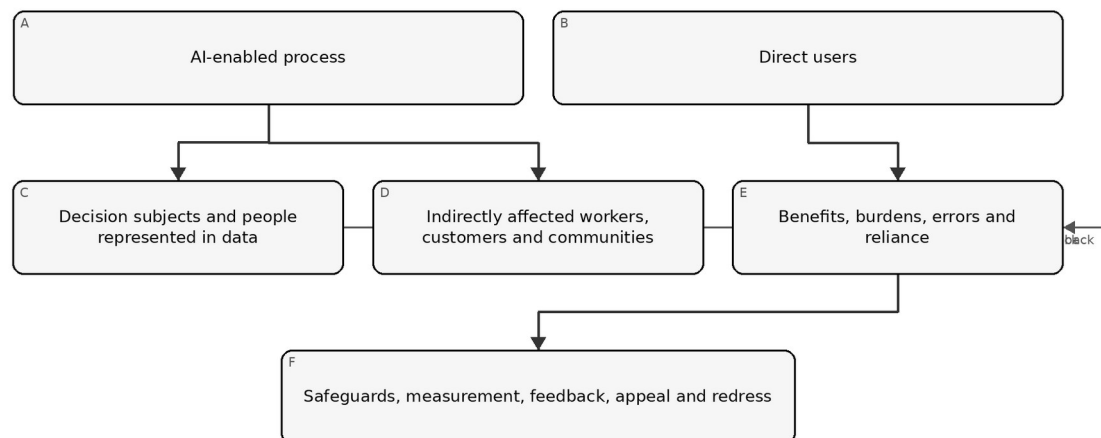


Figure 8. Chapter memory graphic

Accessible explanation: An AI-enabled process can affect direct users, people who are the subject of decisions or represented in data, and people or communities affected indirectly. Mapping considers benefits, burdens, errors and reliance for each group, then determines safeguards, evaluation, feedback, appeal and redress needs.

11.2 Benefit analysis

State expected benefits as testable claims. Consider:

- improved access, quality, timeliness or consistency;
- reduced hazardous or repetitive work;
- better detection or decision support;
- personalization or accessibility;
- cost or resource efficiency; and
- new scientific, educational, creative or operational capability.

For each material benefit, record the beneficiary, metric, baseline, evidence and possible tradeoff. A projected organizational saving does not automatically establish a benefit to affected people.

11.3 Impact and harm scenarios

Use scenario statements that connect cause, event and consequence:

Because [condition or weakness], the system may [error, misuse or failure] during [context], causing [consequence] to [affected party]. Detection may be difficult because [limitation].

Consider:

- physical or psychological safety;
- civil rights, access, eligibility and due process;
- employment, education, housing, credit, insurance or healthcare consequences;
- privacy, surveillance and autonomy;
- economic loss, fraud and manipulation;
- security compromise and operational disruption;
- reputation, dignity, speech and information integrity;
- environmental or community effects where material;
- exclusion through inaccessible design or language; and
- compounded or cumulative effects across systems.

11.4 Severity, exposure and reversibility

Do not compress every dimension into a single score without preserving the narrative. Record:

- severity of plausible consequence;
- frequency and duration of exposure;
- number and vulnerability of affected people;
- reversibility and availability of remedy;
- detectability before harm;
- concentration and correlated-failure potential;
- likelihood where evidence supports a meaningful estimate; and
- uncertainty and confidence.

11.5 Feedback and representation

For material impacts, determine whose perspective is missing. Feedback methods may include interviews, user research, accessibility review, worker consultation, complaint analysis, domain panels, public-interest expertise, community engagement or controlled testing with representative participants.

Document how feedback changed the context, design, evaluation, restrictions or decision. If feedback cannot be obtained, record the limitation and compensating steps.

12. Data, model, software, infrastructure and supplier dependencies

AI risk emerges from the complete system and supply chain, not the model alone.

12.1 Dependency map

Document the deployed chain from input source to output/action:

- input collection and validation;
- data stores, retrieval and transformations;
- model/provider and exact version or endpoint;
- prompts, system instructions, fine-tuning or adapters;
- safety filters, policy engines and guardrails;
- orchestration, agents, tools and permissions;
- application software and user interface;
- identity, access, secrets and network controls;
- logging, monitoring and evaluation services;
- human review and downstream systems; and
- fallback, rollback and retirement dependencies.

12.2 Data context

For each material dataset or data flow, record:

- source, authority and collection purpose;
- population and time period represented;
- selection, labeling and transformation methods;
- quality, completeness and known gaps;
- sensitive or regulated data;
- access, sharing, retention and deletion;
- provenance and version;
- representativeness for the intended context;
- contamination, poisoning or leakage risk; and
- restrictions on training, evaluation or secondary use.

12.3 Model and service context

Record what the organization knows and does not know about:

- model family, version and change behavior;
- training or adaptation information available;
- intended and restricted use;
- evaluated capabilities and limitations;
- security, privacy and safety evidence;
- regional hosting and data practices;
- availability, rate, latency and capacity constraints;
- subcontractors and external tools;
- update notification and rollback options; and
- portability and exit.

Provider opacity is a risk factor, not proof of safety or unsafety. The customer must decide whether available evidence is sufficient for its own use and consequences.

12.4 Concentration and common-mode risk

Identify whether many processes depend on the same model, dataset, cloud, provider, evaluation method or safety control. A single provider update or outage may create correlated failure across otherwise separate applications.

For material concentration, define limits, alternate capability, degraded operation, manual fallback, communication and executive escalation.

13. Misuse, abuse, security, privacy, safety and resilience scenarios

Mapping includes reasonably foreseeable misuse and system interaction, not only intended operation.

13.1 Scenario families

Consider, as relevant:

- unauthorized or prohibited use;
- automation beyond approved authority;
- prompt injection, tool abuse or excessive permissions;
- malicious input, data poisoning or evasion;
- model extraction, privacy leakage or sensitive output;
- insecure integration, secrets exposure or dependency compromise;
- harmful, deceptive, illegal or unsafe content;
- over-reliance, automation bias and loss of human skill;
- inaccurate, fabricated or contextually inappropriate output;
- subgroup or accessibility failure;
- denial of service, capacity exhaustion or supplier outage;
- monitoring/logging failure;
- rollback or stop failure; and
- abuse at scale or coordinated misuse.

13.2 Misuse-case workshop

Field	Question
Actor	Who could misuse the capability, intentionally or accidentally?
Access	What identity, data, prompt, tool or integration access is available?
Path	How could normal controls be bypassed or manipulated?
Consequence	What could happen to people, systems or the organization?
Evidence	What incidents, tests, threat intelligence or analogous cases support the scenario?
Prevention	What authorization, design or process controls reduce opportunity?

Field	Question
Detection	What signal identifies attempted or successful misuse?
Response	Who can contain, revoke, rollback, notify and recover?
Residual risk	What remains and who may accept it?

13.3 Agentic and tool-using AI

When AI can call tools or execute transactions, map:

- allowed and blocked tools;
- identity and credential boundaries;
- read, write, approve and execute permissions;
- transaction, time and resource limits;
- confirmation requirements;
- environment isolation;
- memory and retained context;
- input/output trust boundaries;
- monitoring and complete action traces;
- compensating human review; and
- deterministic emergency stop and revocation.

14. Assumptions, uncertainty, context validity and change triggers

A risk record that hides uncertainty creates false confidence and weakens later decisions.

14.1 Assumption register

For each material assumption, record:

- statement;
- owner;
- basis or evidence;
- confidence;
- consequence if false;
- validation method and due date;
- linked controls; and
- event that invalidates it.

Examples include expected user competence, stable provider behavior, representative evaluation data, adequate human review time, reliable logging or limited deployment scale.

14.2 Uncertainty types

Distinguish uncertainty caused by:

- insufficient or low-quality evidence;
- changing populations or environments;
- model non-determinism;
- supplier opacity;
- rare or emerging failure modes;
- measurement limitations;
- disagreement among experts or affected parties;
- unknown adversarial behavior; and
- incomplete legal or contractual interpretation.

Uncertainty should affect evaluation depth, deployment limits, monitoring, fallback and residual-risk authority.

14.3 Context-validity statement

Every material evaluation result should state the context in which it is believed to apply. At minimum link the result to:

- model/service and version;
- prompts, configuration and tools;
- data/population and time period;
- environment and workflow;
- user and oversight model;
- measured conditions; and
- known exclusions.

14.4 Change triggers

Manual 03 memory graphic 9

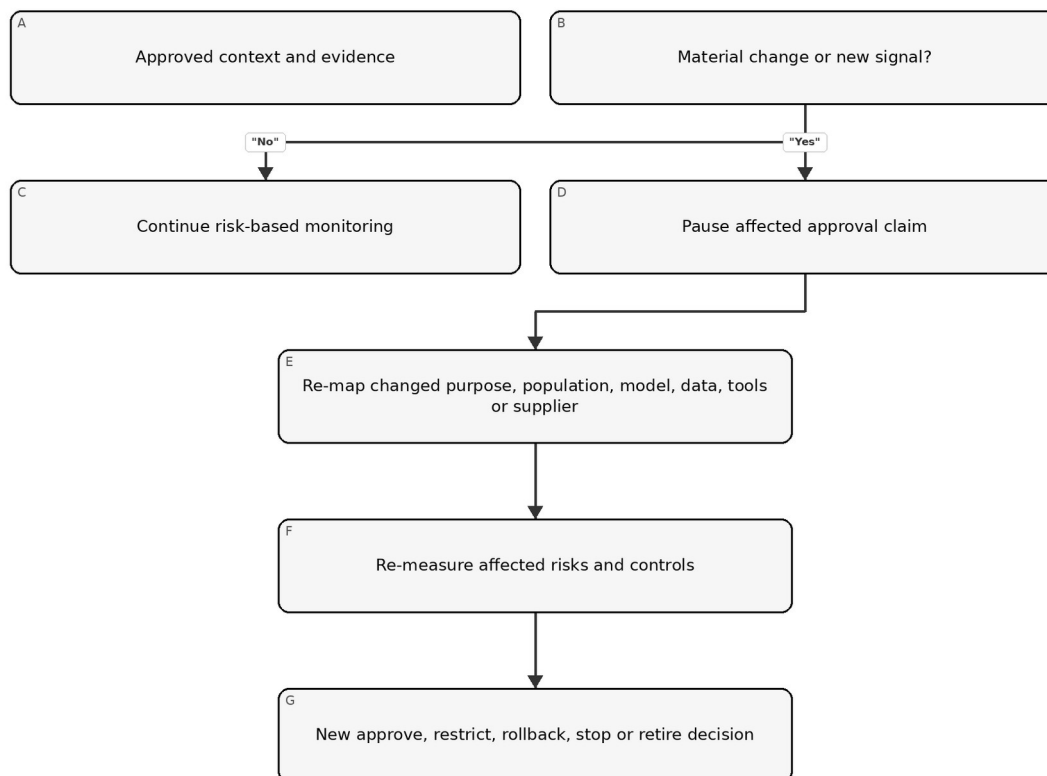


Figure 9. Chapter memory graphic

Accessible explanation: An approved system remains under monitoring. A material change or new signal pauses reliance on affected approval evidence. The organization re-maps what changed, re-evaluates affected risks and controls, and records a new management decision.

Trigger reassessment after changes to purpose, population, geography, model, data, prompts, tools, autonomy, supplier, interface, downstream decision, human oversight or applicable requirement. Incidents, complaints, drift, security findings and failed controls are also triggers.

15. Requirements, standards, stakeholder expectations and risk criteria

MAP should identify the decision constraints that MEASURE and MANAGE must apply.

15.1 Requirement sources

Relevant sources may include:

- law and regulation;
- contracts and customer commitments;
- organizational policy and risk appetite;
- sector rules and professional duties;
- security, privacy, safety, accessibility and quality standards;
- intellectual-property and data-use restrictions;
- product claims and user instructions;
- collective bargaining or workforce commitments; and
- expectations identified through affected-party engagement.

Keep binding requirements separate from voluntary framework guidance. Confirm legal interpretations through the organization's authorized legal process.

15.2 Acceptance criteria

Translate context into criteria that can support a decision. Criteria should state:

- measure or condition;
- threshold or qualitative standard;
- relevant population/scenario;
- evidence source;
- owner and reviewer;
- blocking versus advisory effect;
- exception authority; and
- expiry or reassessment trigger.

Avoid selecting thresholds only because the system already meets them. Document the consequence-based rationale.

15.3 Conflicting objectives and tradeoffs

Trustworthiness characteristics can interact. Improving privacy may reduce available monitoring detail; increasing explainability may expose security-sensitive information; stronger filtering may affect utility or accessibility. Record the tradeoff, affected parties, alternatives, evidence, decision authority and residual risk.

16. MAP evidence package, review and handoff to MEASURE

MAP is complete enough for the next gate when reviewers can identify what must be evaluated and why.

16.1 Minimum MAP package

33. current inventory and ownership record;
34. intended-purpose and prohibited-use statement;
35. system, lifecycle and deployment boundary;
36. actor-task and responsibility map;
37. affected-party and benefit-impact analysis;
38. data/model/software/infrastructure/supplier dependency map;
39. misuse, failure, security, privacy, safety and resilience scenarios;
40. requirement and acceptance-criteria register;
41. assumption, uncertainty and evidence-gap register;
42. initial risk tier and review-path rationale;

- 43. measurement questions and planned evidence; and
- 44. reviewer findings, unresolved dissent and approval conditions.

16.2 MAP review questions

- Does the record describe the actual system/use rather than a generic product?
- Are affected parties broader than direct users where appropriate?
- Are positive impacts, harms and uncertainty considered together?
- Are system and supplier dependencies version-specific?
- Are reasonably foreseeable misuse and failure included?
- Do requirements and acceptance criteria match the context?
- Are evidence gaps visible?
- Does the risk tier match consequence and uncertainty?
- Are material dissent and open questions preserved?
- Are re-mapping triggers explicit?

16.3 Handoff to MEASURE

Convert each material scenario, claim or requirement into one or more evaluation questions. For each question, identify:

- the decision it supports;
- the relevant population and context;
- method and evidence source;
- metric or qualitative rubric;
- threshold and confidence expectation;
- independence and competence needed;
- limitations and uncertainty to report; and
- result that would require restriction, remediation or stop.

Part 2 checkpoint: Chapters 9–16 establish the operational context and evidence questions. Part 3 builds the MEASURE program that tests claims, risks and controls against that context.

17. MEASURE function architecture and TEVV governance

MEASURE produces decision-relevant evidence about system behavior, risk, trustworthiness characteristics, controls and uncertainty in the mapped context.

Testing, evaluation, verification and validation are related but not interchangeable:

- Testing executes defined cases or conditions and records observed results.
- Evaluation judges evidence against criteria and decision needs.
- Verification asks whether specified requirements or design expectations were met.
- Validation asks whether the system is suitable for the intended real-world purpose and context.

Manual 03 memory graphic 10

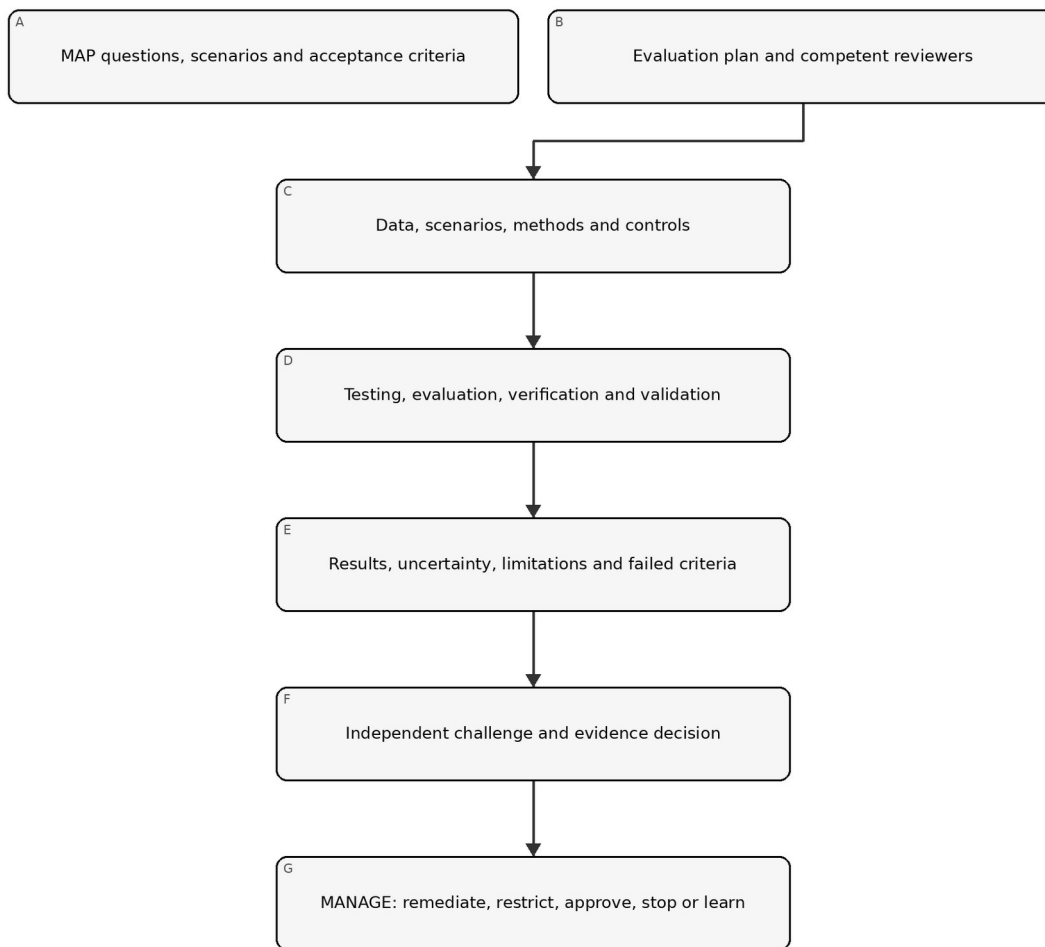


Figure 10. Chapter memory graphic

Accessible explanation: Mapping supplies questions, scenarios and acceptance criteria. The evaluation plan selects competent reviewers, data, scenarios and methods. TEVV produces results with uncertainty and limitations. Reviewers challenge the evidence before management uses it to remediate, restrict, approve, stop or improve the system.

17.1 Measurement principles

Evaluation should be:

- tied to a specific decision;
- representative of the intended and reasonably foreseeable context;
- version-linked and reproducible where feasible;
- proportional to consequence and uncertainty;
- multidisciplinary for socio-technical risks;
- independent enough to provide effective challenge;
- explicit about failures and missing evidence;
- protected from metric manipulation and benchmark leakage; and
- repeated after material change or degraded evidence.

17.2 Measurement inventory

Maintain a register of evaluation questions. Each record should identify:

Field	Minimum content
Question	Claim, requirement, scenario or control being evaluated
Decision	Approval, restriction, control design or monitoring decision supported
Context	Population, environment, workflow, user and version
Method	Test, analysis, review, simulation, experiment, audit or monitoring
Criteria	Threshold, rubric, comparator and blocking condition
Evidence	Dataset, scenario set, logs, expert review or other source
Reviewer	Performer, challenger and required competence
Timing	Pre-release, periodic, continuous, event-triggered or retirement
Limitation	Known uncertainty, exclusion or transfer risk
Outcome	Pass, conditional, fail, inconclusive or not tested

17.3 Measurement governance

Define who may approve methods, thresholds and exceptions. A team that built the system may perform testing, but material risks may require separate validation or challenge. Independence can be achieved through organizational separation, a qualified peer, external specialist, rotating reviewer or audit function proportional to risk.

18. Evaluation plan, methods, data, thresholds and independence

A result is only as useful as the question, method, evidence and decision rule behind it.

18.1 Evaluation-plan contents

The plan should record:

45. system/use, version and context;
46. mapped claims, scenarios and requirements;
47. evaluation questions and decision owners;
48. methods and rationale;
49. test data, cases, scenarios and sampling;
50. relevant populations and subgroups;
51. baseline, comparator and acceptance criteria;
52. execution environment and controls;
53. reviewer roles, competence and independence;
54. security, privacy and safety protections for the evaluation itself;
55. result analysis and uncertainty method;
56. blocking failures and escalation;
57. reproducibility and evidence-retention requirements; and
58. retest and change triggers.

18.2 Method selection

Use multiple methods where one cannot capture the risk:

- quantitative performance testing;
- qualitative rubric-based review;
- scenario and failure-mode testing;
- simulation or controlled experiment;
- usability and human-factors evaluation;
- subgroup and accessibility analysis;
- privacy and security assessment;
- adversarial or red-team testing;

- code, architecture, data and process review;
- supplier-evidence validation;
- operational log, incident and complaint analysis; and
- expert or affected-party review.

18.3 Evaluation data

Verify that evaluation data are appropriate for the claim. Record source, authority, population, time period, collection, preprocessing, labeling, exclusions, quality, sensitive content, version and separation from training or tuning where relevant.

Test data can create privacy, security, safety or intellectual-property risk. Apply access, minimization, isolation, retention and deletion controls.

18.4 Thresholds and rubrics

Define thresholds before examining final results where practical. Explain:

- why the threshold is acceptable for the consequence;
- whether it applies to averages, tails, subgroups or individual events;
- confidence or uncertainty expectation;
- allowed exceptions;
- blocking conditions; and
- who may change it.

Averages may conceal severe subgroup or rare-event failures. Include distribution, worst-case or scenario-specific analysis when consequences justify it.

18.5 Evaluation integrity

Protect evaluation from:

- selecting only favorable cases;
- changing criteria after results are known;
- benchmark contamination or memorization;
- tuning to the test set without independent confirmation;
- excluding failures without documented rationale;
- version mismatch between tested and deployed systems;
- reviewer conflicts of interest; and
- reporting only aggregate scores without limitations.

19. Validity, reliability and task-performance evaluation

Performance evidence must reflect the real task, not only a convenient benchmark.

19.1 Claim decomposition

Break broad claims into observable properties. “Accurate” might include:

- correct classification or prediction;
- completeness of required information;
- calibration or confidence behavior;
- consistency across repeated runs;
- stability across expected variation;
- timeliness and latency;
- appropriate abstention or uncertainty signaling; and
- acceptable error behavior across relevant populations.

19.2 Validity

Ask whether the evaluation actually supports the intended inference:

- Does the test represent the task and population?

- Is the reference or ground truth credible?
- Are labels and rubrics sufficiently reliable?
- Are important confounders controlled or reported?
- Does offline performance transfer to the workflow?
- Does human interaction change the result?
- Are downstream actions included?

19.3 Reliability

Evaluate consistency across:

- repeated executions;
- seeds or non-deterministic runs;
- time and operational load;
- devices, regions or environments;
- relevant input variation;
- reviewers or annotators; and
- model/provider versions.

For generative systems, use multiple samples and structured review rather than presenting one favorable output as evidence.

19.4 Error analysis

Do not stop at a single score. Characterize:

- error types and severity;
- false-positive and false-negative consequences;
- tail and rare-event behavior;
- subgroup and intersectional variation where relevant;
- abstention and escalation behavior;
- error detectability by users;
- downstream amplification; and
- operational conditions linked to failure.

19.5 Comparative evaluation

Compare against the current process, a simpler system, qualified human performance or another reasonable baseline. Record differences in cost, time, access, quality, safety and burden. The relevant question is often whether the AI-enabled process improves the overall decision system, not whether the model exceeds one isolated metric.

20. Safety, security, robustness and resilience evaluation

Material AI systems require evidence about behavior under stress, attack, failure and recovery.

20.1 Evaluation model

Manual 03 memory graphic 11

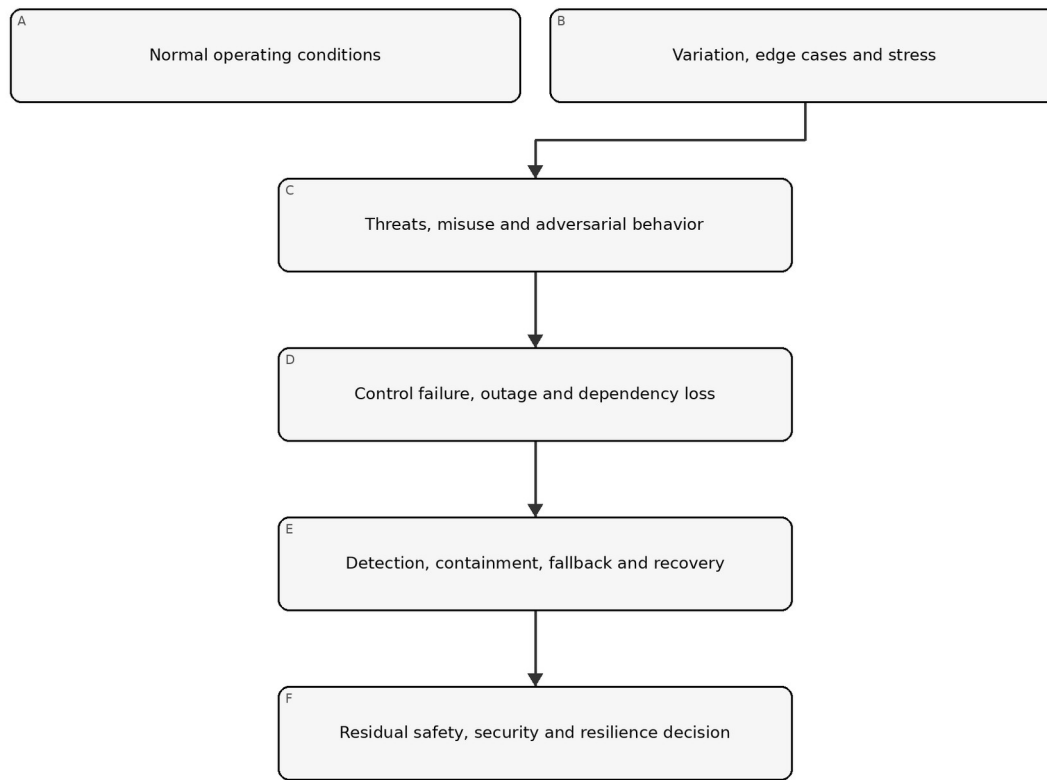


Figure 11. Chapter memory graphic

Accessible explanation: Evaluation begins with normal operation, expands to edge cases and stress, then tests threats and misuse. It also examines control or dependency failure and whether the organization can detect, contain, fall back and recover before deciding what residual risk remains.

20.2 Safety evaluation

As relevant, evaluate:

- hazards and unsafe actions;
- foreseeable use and misuse;
- unsafe interaction with people or physical systems;
- failure detection and safe state;
- human intervention time;
- emergency stop and manual alternative;
- cascading consequences; and
- recovery validation.

Use domain safety expertise when consequences extend beyond ordinary software failure.

20.3 Security evaluation

Scope the full AI system. Consider:

- data poisoning and malicious inputs;
- evasion and adversarial examples;

- prompt injection and indirect prompt injection;
- excessive agency and tool misuse;
- model, prompt, data or secret extraction;
- insecure output handling;
- access-control and identity weaknesses;
- dependency and software supply-chain compromise;
- denial of service and resource exhaustion;
- logging or monitoring bypass; and
- unauthorized model/configuration change.

Use controlled environments and explicit authorization for adversarial testing. Do not expose real sensitive data or production systems unnecessarily.

20.4 Robustness

Test behavior under expected variation and plausible perturbation, including noisy, incomplete, ambiguous, out-of-distribution, multilingual or intentionally manipulated inputs where relevant. Robustness is context-specific; resistance to one test does not prove broad robustness.

20.5 Resilience and recovery

Exercise:

- provider or model outage;
- latency or capacity degradation;
- safety-filter failure;
- corrupted or unavailable data;
- loss of logging or monitoring;
- credential revocation;
- rollback to a known version;
- degraded or manual operation;
- incident communication; and
- restoration validation.

Record recovery time, recovery point, manual workload, data reconciliation and residual limitations.

21. Accountability, transparency, explainability and interpretability evidence

Information is useful only when it enables the intended person to understand, act, challenge or seek remedy.

21.1 Audience-specific transparency

Identify what each audience needs:

Audience	Typical need
User/operator	Purpose, correct use, limits, verification, escalation and stop instructions
Affected person	AI involvement, relevant consequence, accessible explanation, correction/appeal path
Owner/management	Risk, evidence, failures, residual risk, incidents and decision conditions
Technical team	Versions, data, methods, limitations, monitoring and change details
Reviewer/auditor	Traceable evidence, approvals, criteria, workpapers and control operation
Regulator/customer	Information required by applicable authority or contract, subject to legal review

21.2 Explainability and interpretability

Evaluate whether the explanation method is appropriate for the model, decision, audience and consequence. Test:

- fidelity to actual system behavior;
- stability and consistency;
- completeness for the decision need;
- understandability and accessibility;
- actionability;
- resistance to misleading presentation; and
- security/privacy tradeoffs.

An explanation that sounds plausible but does not reflect the system is worse than an honest limitation.

21.3 Traceability and accountability

Confirm that the organization can reconstruct:

- what system/version acted;
- relevant input and context, subject to privacy limits;
- output or action;
- human review or override;
- applicable policy and control state;
- decision authority;
- incident or complaint linkage; and
- later correction or change.

22. Privacy and harmful-bias evaluation

Privacy and fairness-related risks require context, affected-party analysis and more than one aggregate metric.

22.1 Privacy evaluation

Evaluate the full data lifecycle:

- authority and purpose;
- minimization and necessity;
- notice and meaningful choice where applicable;
- sensitive data handling;
- training, retrieval, prompt and output exposure;
- inference or re-identification risk;
- retention and deletion;
- access, sharing and subprocessors;
- monitoring/logging privacy; and
- correction, access or other applicable rights processes.

Technical testing may include leakage, memorization, extraction or inference analysis as relevant, but must be paired with governance and process evidence.

22.2 Harmful-bias evaluation

Start with mapped harms and affected groups. Determine:

- which outcomes or errors matter;
- which groups and intersections require analysis;
- what comparison is meaningful;
- whether data support the inference;
- whether the metric reflects the real decision process;
- whether human review mitigates or amplifies the effect;
- what threshold or qualitative judgment applies; and
- what remedy exists.

No single fairness metric is universally correct. Record the rationale, tradeoffs, legal review where needed, limitations and residual risk.

22.3 Process and outcome evidence

Review both:

- process evidence: participation, data governance, design choices, review, documentation and complaint handling; and
- outcome evidence: performance, error, allocation, burden or impact patterns in the real context.

22.4 Accessibility and language

Evaluate whether interfaces, notices, explanations, support and appeal paths work for relevant disability, literacy, language and technology-access needs. Accessibility defects can create systematic exclusion even when model performance appears acceptable.

23. Human factors, oversight and affected-party evaluation

The performance of the human-AI team may differ materially from the model measured alone.

23.1 Oversight-effectiveness test

Evaluate whether the oversight person:

- recognizes when AI is involved;
- understands purpose and limitations;
- has enough information and time;
- can identify important errors;
- can disagree without penalty;
- can correct, override or stop;
- uses escalation and fallback correctly; and
- leaves an auditable record.

Measure automation bias, complacency, workload, alert fatigue, skill degradation and differences across experience levels.

23.2 Human-AI workflow evaluation

Compare at least where material:

- human-only baseline;
- AI-only result for diagnostic understanding;
- human with AI assistance;
- different interface or explanation designs; and
- degraded or fallback operation.

The approved operating model should be the one actually evaluated.

23.3 Affected-party evaluation

Methods may include accessible usability tests, interviews, complaint analysis, controlled pilots, journey review, participatory evaluation or domain-expert panels. Protect participants and sensitive information, and avoid placing the burden of proving harm entirely on affected people.

23.4 Appeals, correction and redress

Test whether a person can:

- recognize a relevant decision or output;
- obtain understandable information;
- submit correction or challenge;
- reach a competent human;
- receive timely handling;
- prevent repeated propagation where appropriate; and
- obtain the remedy authorized by policy or law.

24. Uncertainty, limitations, result review and MEASURE evidence package

Decision makers need a faithful account of what the evidence supports, what it does not support and how quickly it can become stale.

24.1 Result record

For each material evaluation, retain:

- evaluation ID and linked MAP question;
- system, model, data, prompt/configuration and software versions;
- method, environment and execution date;
- dataset/scenario set and sampling;
- criteria and pre-defined thresholds;
- performer, reviewer and competence;
- detailed and summarized results;
- failures, exclusions and anomalies;
- uncertainty and confidence;
- limitations and transfer conditions;
- security/privacy handling;
- findings and remediation;
- retest results; and
- management disposition.

24.2 Uncertainty statement

State:

59. what is known with reasonable support;
60. what remains uncertain;
61. why uncertainty exists;
62. how uncertainty could affect people or decisions;
63. controls or deployment limits used because of it;
64. monitoring or research planned; and
65. who accepted the remaining uncertainty and until when.

24.3 Result classification

- Pass: evidence meets defined criteria in the tested context.
- Conditional: criteria are met only under documented restrictions or compensating controls.
- Fail: one or more blocking criteria are not met.
- Inconclusive: evidence is insufficient or inconsistent for the decision.
- Not tested: the question remains open and cannot be represented as satisfied.

Fail closed when a mandatory result is failed, inconclusive, missing, version-mismatched, expired or invalidated by material change.

24.4 Evidence review

Manual 03 memory graphic 12

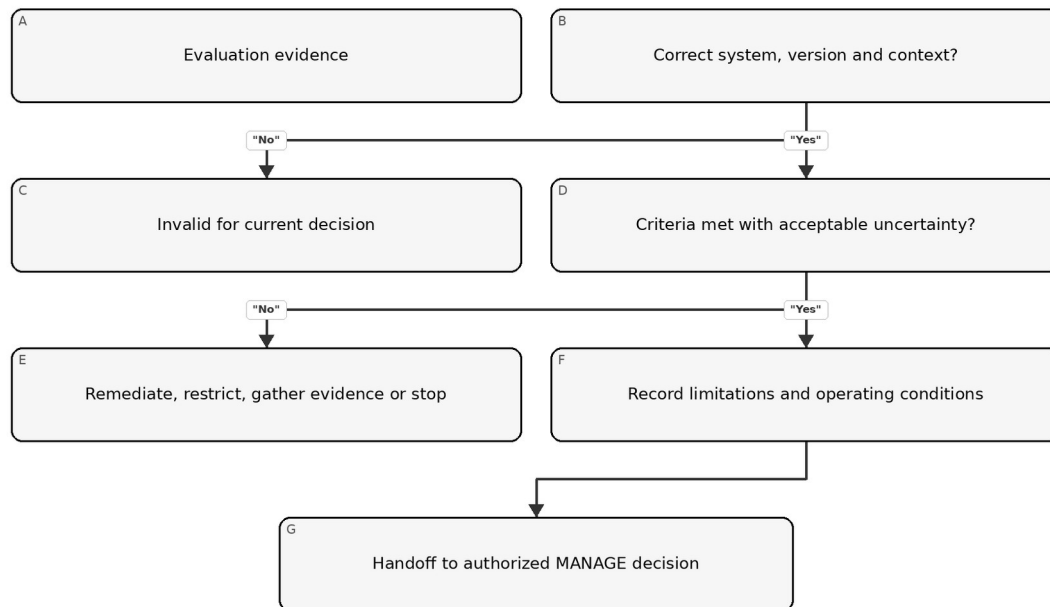


Figure 12. Chapter memory graphic

Accessible explanation: Review first confirms that evidence applies to the correct system, version and context. If not, it is invalid. If criteria or uncertainty are unacceptable, the organization remediates, restricts, gathers more evidence or stops. Acceptable evidence is handed to an authorized management decision with limitations and conditions preserved.

24.5 Minimum MEASURE package

66. approved evaluation plan;
67. question-to-method matrix;
68. controlled datasets and scenario manifests;
69. environment and version record;
70. executed results and analysis;
71. trustworthiness-characteristic evidence relevant to context;
72. human/affected-party evaluation where needed;
73. failed, inconclusive and untested items;
74. uncertainty and limitations statement;
75. reviewer challenge, findings and remediation;
76. retest evidence; and
77. decision-ready summary linked to detailed workpapers.

Part 3 checkpoint: Chapters 17–24 create evidence without overstating it. Part 4 uses that evidence to prioritize, treat, decide, monitor, respond and improve through MANAGE.

25. MANAGE function architecture and risk prioritization

MANAGE converts mapped context and measured evidence into prioritized treatment, accountable decisions, operational controls and improvement.

Manual 03 memory graphic 13

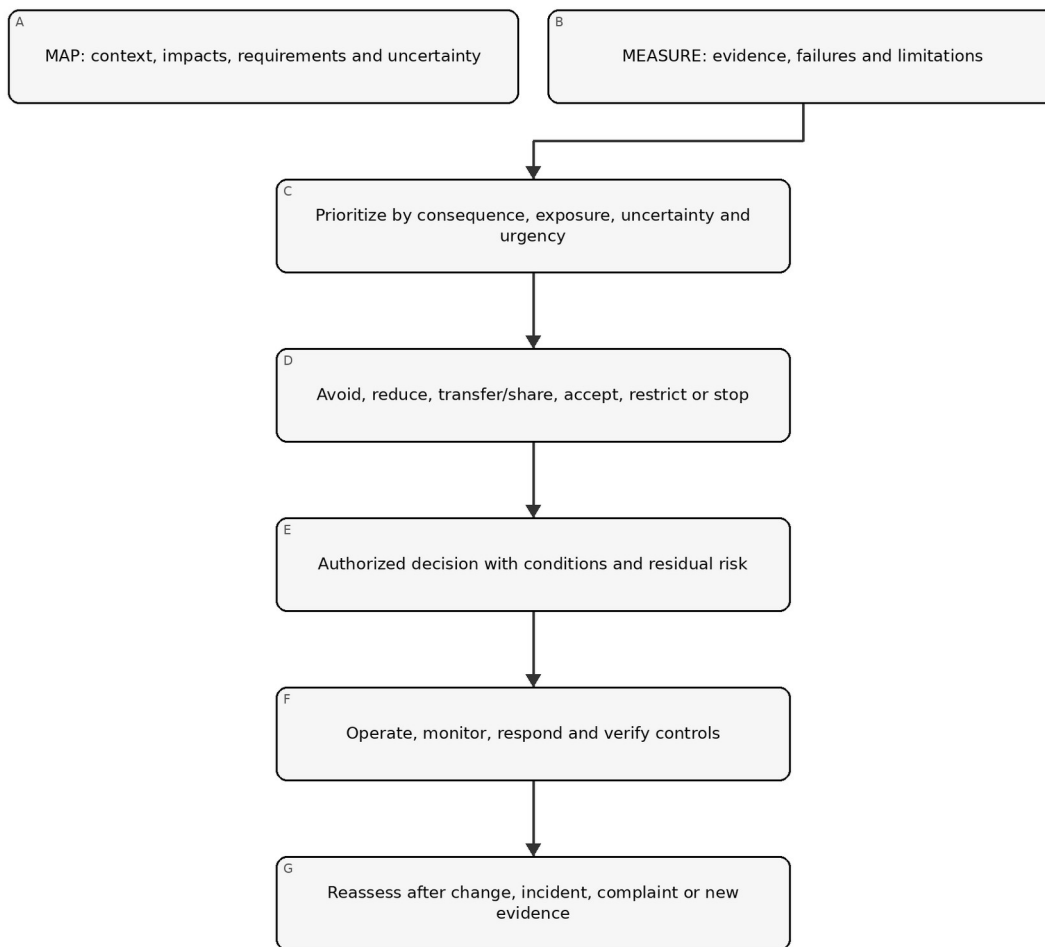


Figure 13. Chapter memory graphic

Accessible explanation: Management combines mapped context with measured evidence, prioritizes risk, selects treatment, and records an authorized decision with conditions and residual risk. Operations then monitor and verify controls. Changes and real-world signals trigger reassessment.

25.1 Prioritization record

Prioritize using more than a generic score. Record:

- plausible consequence and reversibility;
- affected population, vulnerability and scale;
- exposure, frequency and duration;
- likelihood where supportable;
- uncertainty and evidence quality;
- control strength and detectability;
- urgency, including active incidents or legal deadlines;
- common-mode or concentration risk;
- opportunity and benefit tradeoffs; and
- dependencies among risks.

High uncertainty can justify stronger controls or a narrower pilot even when likelihood is unknown.

25.2 Portfolio view

Aggregate AI risks across systems without losing system-level accountability. Management should identify:

- multiple uses relying on the same model/provider;
- repeated control failures;
- cumulative effects on the same population;
- scarce oversight or validation capacity;
- correlated cybersecurity, privacy or operational risk;
- exceptions and residual-risk decisions nearing expiry; and
- systems whose combined autonomy or scale exceeds original assumptions.

25.3 Decision cadence

Use event-driven review in addition to calendars. Review priority when a material change, incident, complaint, evaluation failure, supplier notice, legal development, risk-tolerance change or new affected population appears.

26. Risk treatment, controls, ownership and action planning

Treatment should change actual exposure, behavior or recovery capability, not only create documentation.

26.1 Treatment choices

- Avoid: do not start, remove a feature or retire the use.
- Reduce: change purpose, design, data, model, autonomy, population, process or controls.
- Share/transfer: allocate defined duties contractually or through insurance while retaining non-transferable accountability.
- Accept: authorize residual risk within documented authority and conditions.
- Pilot/restrict: limit geography, population, users, data, autonomy, duration or volume to gather evidence safely.
- Stop/rollback: suspend operation or return to a known safe state.

26.2 Control design record

Field	Minimum content
Risk/scenario	Mapped cause-event-consequence and affected parties
Objective	What exposure, failure or consequence the control addresses
Control	Preventive, detective, corrective or recovery activity
Owner/operator	Accountable owner and person/system performing it
Trigger/frequency	Continuous, transaction, release, periodic or event-driven
Evidence	Record proving design and operation
Threshold	Condition that causes action or escalation
Dependency	Data, tool, supplier, reviewer or infrastructure needed
Limitation	Known gap or failure mode
Test	How design and operating effectiveness are evaluated
Residual risk	What remains after the control

26.3 Control hierarchy

Prefer controls that remove or constrain risk at the source before relying solely on users to catch errors. Depending on context:

78. eliminate the use or hazardous capability;
79. reduce scope, autonomy, data or access;
80. redesign architecture, model, workflow or interface;
81. implement technical and process controls;
82. add competent human oversight and independent verification;

83. add warnings, instructions and training; and
84. monitor, respond and provide remedy.

Training and disclaimers are rarely sufficient controls for high-consequence system behavior.

26.4 Action plan

Every remediation item should have an owner, due date, severity, dependency, acceptance criteria, evidence, retest method and escalation path. A due date does not reduce current risk; interim restrictions may be needed until remediation is verified.

27. Residual-risk decisions, exceptions and accountable acceptance

Residual risk is a decision about remaining exposure after evidence and controls, not a label generated by a scoring tool.

27.1 Acceptance record

Record:

- exact system/use and version;
- decision scope, population, geography and duration;
- relevant risks, benefits and affected parties;
- evidence reviewed and unresolved uncertainty;
- controls and operating conditions;
- failed, inconclusive or untested items;
- residual-risk rationale;
- decision authority and competence;
- approval, conditional approval, restriction or rejection;
- expiration and review date;
- automatic reassessment/stop triggers; and
- dissent or minority view.

27.2 Authority levels

Align acceptance authority to consequence. Low bounded risk may be accepted by the accountable owner within policy. Moderate risk may require cross-functional approval. High-consequence, regulated, safety-sensitive or portfolio-level risk may require executive or board-designated authority and independent challenge.

No one should accept risk on behalf of affected parties merely because the organization benefits. Legal duties and non-transferable obligations remain binding.

27.3 Exceptions

An exception should be:

- narrow and time-bound;
- approved by authorized people;
- explicit about the requirement not met;
- supported by risk analysis;
- paired with compensating controls or restrictions;
- monitored;
- visible to assurance functions; and
- automatically expired unless renewed through a new decision.

27.4 Decision quality check

Reject or return a decision if evidence is missing, version-mismatched, expired, materially changed, internally inconsistent or unable to support the asserted context. "Business urgency" should be recorded as a factor, not used to erase risk.

28. Deployment, release, restriction, stop, rollback and retirement

Release is an evidence-based risk decision for an exact configuration, not the end of risk management.

28.1 Release gate

Manual 03 memory graphic 14

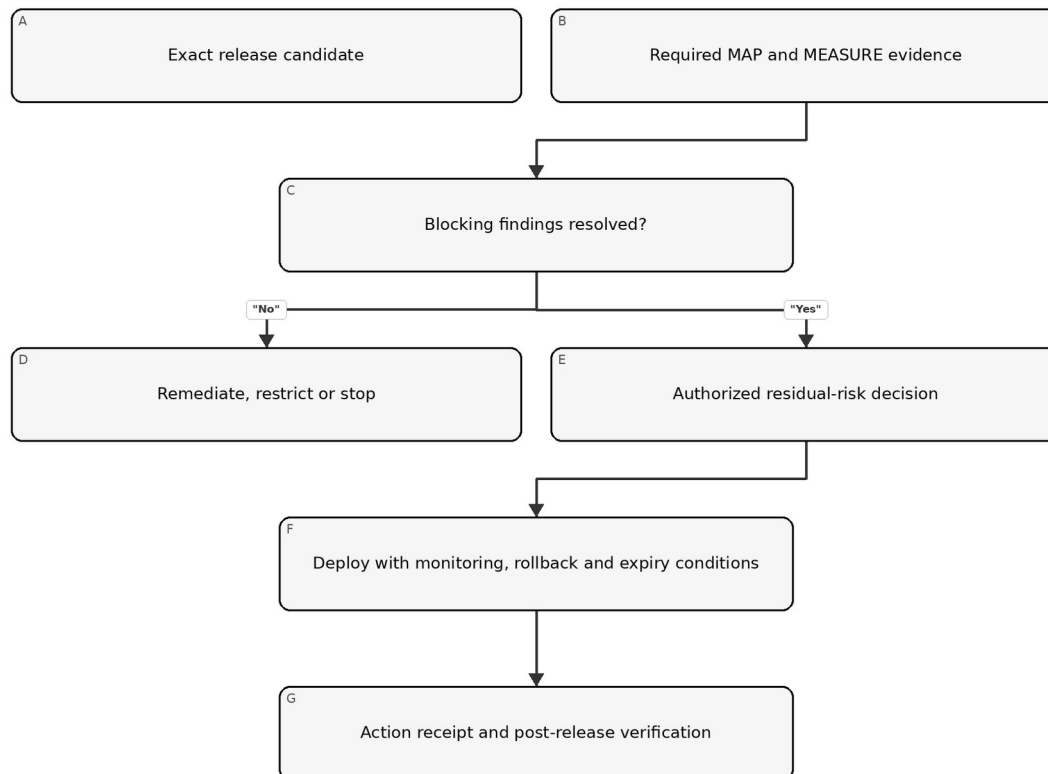


Figure 14. Chapter memory graphic

Accessible explanation: The release gate identifies the exact candidate and required evidence. Blocking findings lead to remediation, restriction or stop. When evidence supports the decision, an authorized person accepts residual risk and deployment occurs with monitoring and rollback conditions. The release and follow-up are recorded.

28.2 Minimum release evidence

- approved purpose and context;
- current risk tier;
- exact model, data, prompt/configuration, software and dependency versions;
- required evaluation results and limitations;
- security, privacy, safety, accessibility and domain reviews as applicable;
- supplier evidence and contract conditions;
- user and oversight instructions;
- monitoring and incident readiness;
- stop, rollback, fallback and recovery test;
- unresolved findings and accepted conditions;
- residual-risk approval; and

- release record and checksum/version identifiers.

28.3 Progressive deployment

Use staged or canary release, limited populations, lower autonomy, rate limits, approval gates, parallel human process or shadow evaluation when this reduces uncertainty without exposing people to unacceptable risk.

28.4 Stop and rollback

Define objective triggers, authority and technical capability. Examples:

- severe harm or credible imminent harm;
- security compromise or sensitive-data exposure;
- material performance or subgroup degradation;
- repeated harmful or prohibited outputs;
- loss of required human oversight;
- invalid or missing required evidence;
- unapproved provider/model change;
- monitoring or logging failure for a critical control; and
- binding legal or contractual prohibition.

Test stop and rollback before relying on them. Confirm identity revocation, queued actions, downstream reconciliation, communications and restoration validation.

28.5 Retirement

Retirement should address data and record retention/deletion, model and credential access, integrations, user communication, supplier termination, pending decisions, legal hold, knowledge transfer, archive, monitoring shutdown and confirmation that the system no longer acts.

29. Monitoring, drift, incidents, complaints, appeals and corrective action

Operational evidence determines whether assumptions and controls remain valid after release.

29.1 Monitoring design

For each measure, define:

- question and risk addressed;
- data source and privacy boundary;
- population and version;
- calculation or rubric;
- baseline and threshold;
- owner and reviewer;
- frequency or latency;
- action when breached;
- false-positive/false-negative limitation; and
- evidence retention.

Monitor system behavior, human interaction, controls, affected outcomes, supplier changes and the monitoring system itself.

29.2 Drift and degradation

Distinguish changes in input data, population, concept/relationship, model behavior, workflow, users, environment and outcome. A metric may remain stable while the consequence changes, so combine quantitative signals with incidents, complaints, overrides and domain review.

29.3 Incident process

Manual 03 memory graphic 15

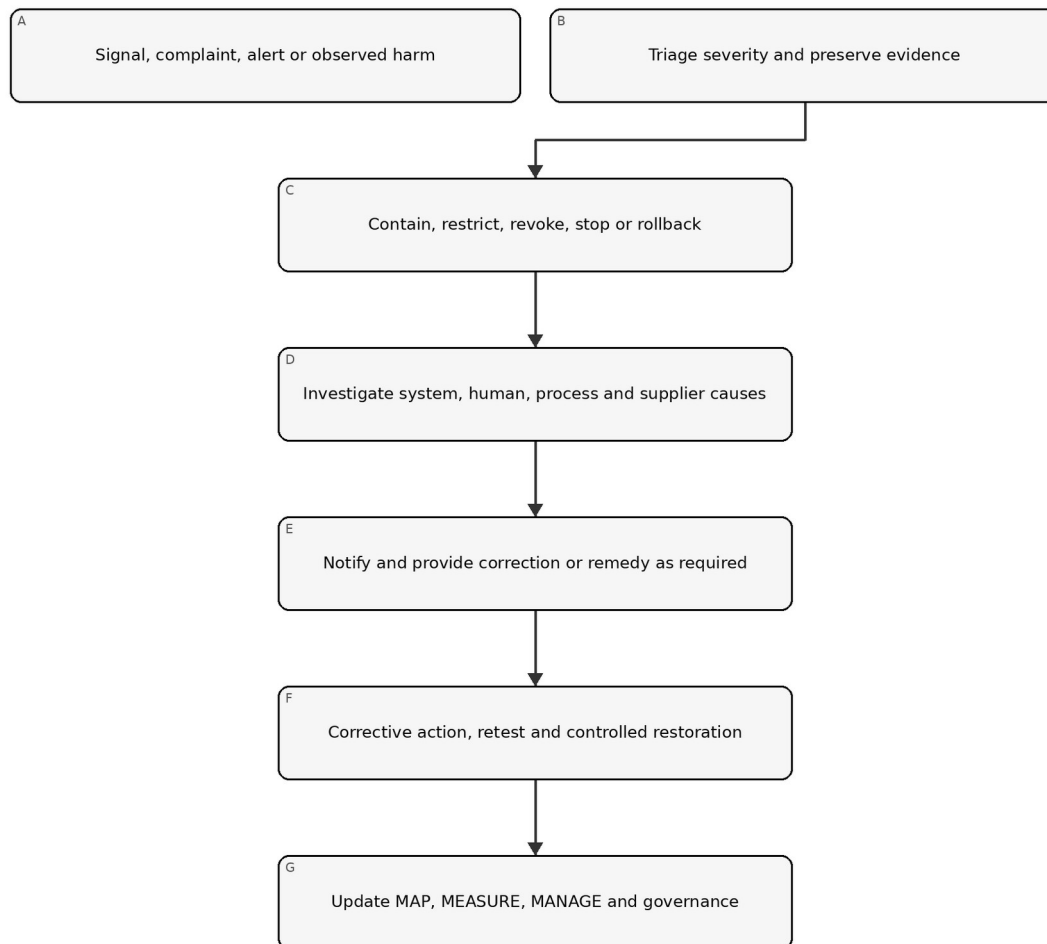


Figure 15. Chapter memory graphic

Accessible explanation: An incident begins with a signal or complaint, followed by triage and evidence preservation. The organization contains the issue, investigates technical and organizational causes, provides required notification or remedy, verifies corrective action and updates the full risk-management cycle.

29.4 Complaint, appeal and redress

Treat complaints as risk evidence, not only customer-service tickets. Link them to the system version and context, protect complainants, support accessible channels, prevent retaliation, define service levels, enable competent human review and track repeated patterns.

29.5 Corrective action

Separate immediate correction from root-cause corrective action. Record:

- issue and consequence;
- containment/correction;
- cause analysis across technology, people, process and governance;
- systemic extent;
- action owner and due date;

- verification of implementation;
- effectiveness retest;
- recurrence monitoring; and
- updates to related systems, policies, training and supplier controls.

30. Change, suppliers, generative AI and agentic-system governance

Material change invalidates affected assumptions and evidence until impact is assessed.

30.1 Change classes

Review changes to:

- purpose or prohibited-use boundary;
- population, geography, language or scale;
- data source, feature, retention or transformation;
- model, provider, version, fine-tuning or prompt;
- software, tool, integration or permission;
- autonomy or downstream action;
- interface, notice or human oversight;
- supplier/subprocessor and contract;
- monitoring and logging; and
- applicable requirement or risk tolerance.

Classify changes as non-material, material with bounded review, or material requiring full reassessment. Preserve rationale and reviewer.

30.2 Supplier change control

Require notification where feasible, but assume providers may change behavior without complete notice. Use version pinning, regression tests, monitoring, contract rights, evidence refresh, fallback and exit planning proportional to dependency.

30.3 Generative AI profile integration

When generative AI is in scope, apply NIST AI 600-1 as a companion profile to the general AI RMF process. Evaluate applicable GenAI risk families and profile actions without treating every action as universally required.

At minimum consider:

- confabulation and unsupported content;
- dangerous, hateful or abusive content;
- data privacy and intellectual-property concerns;
- information integrity and provenance;
- cybersecurity and prompt/tool attacks;
- human over-reliance and emotional or social effects;
- harmful bias and homogenization;
- misuse enablement and abuse at scale;
- environmental and resource effects where material;
- value-chain and component-integration risk; and
- evaluation limitations.

Manual 04 provides the deeper NIST AI 600-1 implementation.

30.4 Agentic systems

For tool-using or autonomous agents, implement and test:

- narrow identities and least privilege;
- tool allowlists and prohibited actions;
- transaction, time, rate and resource limits;

- human confirmation for consequential actions;
- input/content trust boundaries;
- environment isolation;
- complete action traces;
- memory and retention controls;
- deterministic revocation and emergency stop;
- rollback and downstream reconciliation; and
- explicit responsibility for delegated decisions.

31. Metrics, assurance, internal audit and continual improvement

Assurance asks whether governance and controls are designed and operating effectively; it does not certify that risk is eliminated.

31.1 Management metrics

Use measures linked to decisions, such as:

- active AI uses with current owner, tier and approval;
- material systems linked to deployed-version evaluation evidence;
- high-severity failures and remediation age;
- expired exceptions and residual-risk decisions;
- incidents, complaints, appeals, overrides and recurrence;
- threshold breaches and response time;
- supplier evidence and unreviewed changes;
- corrective-action effectiveness retests; and
- systems restricted, stopped or redesigned because evidence was inadequate.

Avoid rewarding document volume or suppressing incident reporting.

31.2 Control assurance

Test both:

- design effectiveness: the control, if operated as designed, addresses the risk in context; and
- operating effectiveness: the control actually operated for the required population and period, produced evidence, detected exceptions and caused required action.

31.3 Internal audit

An audit program should define risk-based scope, criteria, competence, independence, sampling, evidence, findings, reporting and follow-up. Auditors should not audit their own work without safeguards. Preserve the distinction between internal audit, technical evaluation, compliance review, certification and regulatory examination.

31.4 Finding classification

Classify findings based on consequence, systemic extent, control failure, recurrence, evidence and urgency. Every finding should identify criteria, condition, evidence, impact/risk, owner, action, due date and closure test.

31.5 Learning loop

Use incidents, near misses, complaints, audits, supplier events and successful controls to update inventory, risk criteria, scenarios, evaluation methods, thresholds, training, design standards and portfolio decisions.

32. Implementation roadmaps, maturity, profiles and framework revision

Organizations should start with a controlled minimum and add depth where risk, complexity and evidence demand it.

32.1 Essential roadmap

First 30 days

- designate accountable AI-risk leadership;
- issue interim approved/prohibited-use rules;
- begin AI discovery and inventory;
- define a simple risk-routing method;
- identify material existing uses;
- establish incident and stop contacts; and
- select a small evidence template set.

Days 31–90

- complete context and minimum evaluation for material uses;
- assign residual-risk authority;
- implement supplier and change checks;
- document user/oversight instructions;
- define monitoring thresholds; and
- remediate or restrict uses lacking supportable evidence.

Months 4–12

- reconcile inventory periodically;
- test controls and corrective actions;
- improve incident/complaint handling;
- build management metrics;
- perform risk-based internal review; and
- update the target profile.

32.2 Structured roadmap

Add formal governance, cross-functional lifecycle gates, controlled TEVV, version/lineage, supplier evidence, privacy/security/accessibility/domain review, operational metrics, periodic management review, internal audit and controlled evidence retention.

32.3 Enhanced roadmap

Add executive/board oversight, independent validation, affected-party engagement, adversarial and stress evaluation, continuous monitoring for key risks, rehearsed stop/rollback, portfolio concentration analysis, enhanced supplier surveillance and formal residual-risk expiration.

32.4 Maturity model

Level	Observable state
0 — Uncontrolled	AI use is unknown or unmanaged; ownership and evidence are absent
1 — Initial	Basic inventory, policy, owner and case-by-case review exist
2 — Repeatable	Risk routing, lifecycle gates, evaluation and evidence are consistently used
3 — Measured	Operational metrics, control testing, supplier/change review and management decisions are linked
4 — Adaptive	Incidents, affected-party evidence, portfolio risk and assurance systematically drive improvement

Maturity is not a certification. A Level 4 process can still make a poor system decision, and a small organization can operate strong controls without elaborate bureaucracy.

32.5 Current and target profiles

Create a current profile describing actual outcomes and evidence, and a target profile describing desired outcomes based on risk and obligations. The gap plan should identify priority, owner, resources, dependencies, date, evidence and interim restriction.

32.6 Framework revision protocol

When NIST publishes a revised AI RMF:

85. freeze the current Manual 03 release candidate;
86. verify the final official publication and version;
87. compare functions, categories, subcategories, terminology and guidance;
88. classify impacts on chapters, templates, graphics, profiles and crosswalks;
89. update the English controlled source first;
90. reopen affected source and technical reviews;
91. retranslate changed meaning through controlled human-reviewed localization;
92. regenerate DOCX/PDF artifacts and rerun accessibility, visual and security QA; and
93. publish a versioned change record without silently overwriting the prior baseline.

32.7 Final implementation boundary

Implementing this manual can strengthen risk governance and evidence. It does not prove that an AI system is trustworthy, eliminate harm, satisfy every law, establish ISO/IEC 42001 conformity, create certification or constitute an audit opinion. The organization remains accountable for the actual system, context, obligations, decisions and effects.

Part 4 checkpoint: Chapters 25–32 complete the GOVERN–MAP–MEASURE–MANAGE operating cycle and connect it to deployment, operations, incidents, assurance, roadmaps and controlled framework revision.